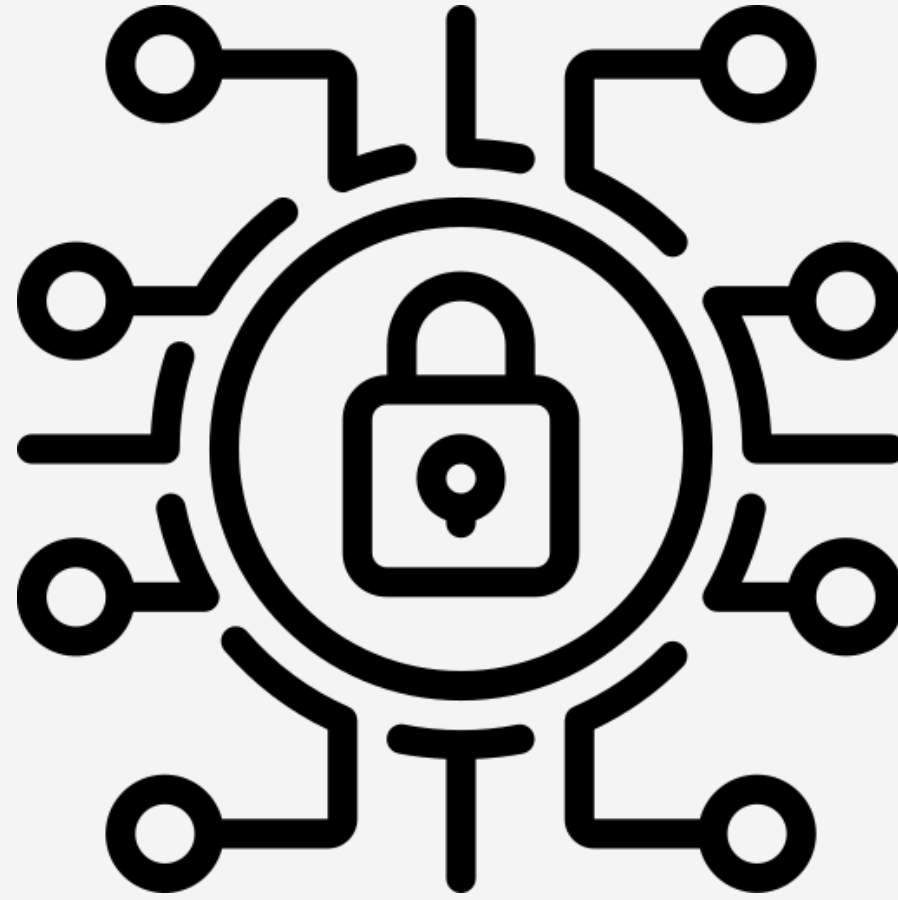


Yönetim Bilişim Sistemlerine Giriş

13. Hafta

Dr. Öğr. Üyesi Murat Kılınç

Enformasyon Sistemlerinin Güvenliđi



Tehdit Türleri (Dış)

Malware (Zararlı Yazılımlar):

- Virüsler:** Bilgisayara bulaşarak dosyaları bozabilir veya sistemi yavaşlatabilir.
- Trojan (Truva Atı):** Güvenli gibi görünen bir yazılım, arka planda zararlı eylemler yapar.
- Ransomware (Fidye Yazılımları):** Kullanıcı dosyalarını şifreler ve fidye karşılığı açar.

Phishing (Oltalama):

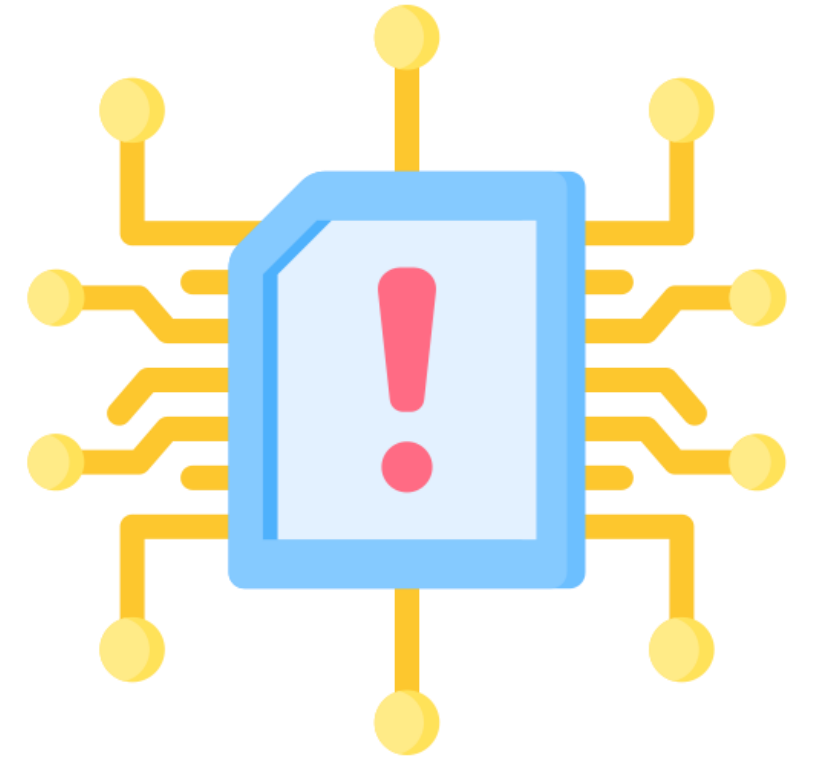
- Kullanıcıları aldatmak için sahte e-postalar veya web siteleri oluşturulur.
- Örnek: “Banka hesabınızda sorun var” mesajı ile bilgileriniz çalınır.

DDoS (Dağıtılmış Hizmet Reddi Saldırısı):

- Sistemi aşırı trafikle meşgul ederek çalışmaz hale getirme. (netscout.com)

Zero-Day Exploits:

- Henüz fark edilmemiş güvenlik açıklarını hedef alan saldırılar.



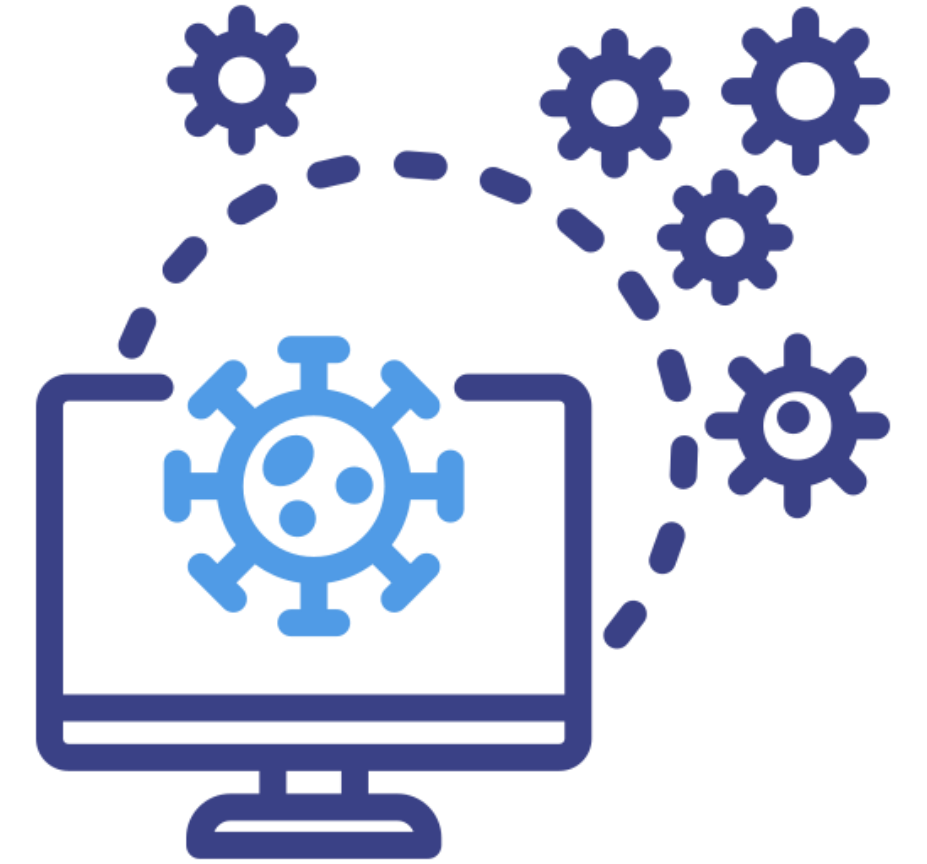
Tehdit Türleri (İç)

Bilinçsiz Kullanıcı Hataları:

- Örnek: Hassas dosyaların yanlış kişilere gönderilmesi.
- Güvenlik politikalarına uymama.

Kasıtlı Çalışan Eylemleri:

- İşten ayrılan veya memnun olmayan çalışanların şirket verilerine zarar vermesi.
- Verilerin üçüncü şahıslarla paylaşılması.



Sosyal Mühendislik

İnsan psikolojisini hedef alarak bilgi çalma!

Bankanızdan geliyoruz, hesabınızda sorun var. Bu bağlantıya tıklayarak giriş yapın (**Oltalama**).

Saldırgan bir şirket çalışanını arar ve teknik destek ekibinden olduğunu iddia eder: (**Pretexting – Bahane Uydurma**)

“Sunucu erişim bilgilerinize ihtiyacımız var, yoksa işleminiz durabilir.

Bir ofis otoparkına “Maaş Listesi.pdf” isimli bir USB bırakılır. (**Baiting - Yemleme**)

Ofis girişinde kartını okutarak içeri giren bir çalışanın arkasından saldırgan da içeri girer. (**Tailgating – Ardına Takılma**)

Bir kişi, çalışana telefon açar ve bir hediye kartı vereceğini söyler: (**Quid Pro Quo – Karşılık Bekleme**)
“Bilgisayarınızın güvenlik durumunu kontrol etmek için oturum açma bilgilerinizi paylaşır mısınız?”

Bir kafede, kurbanın ATM şifresini girerken arkasından izlemek. (**Shoulder Surfing Omuz Sörfü**)

Doğal Tehditler

Doğal Afetler (Natural Disasters)

•Açıklama:

Deprem, sel, fırtına gibi doğal olaylar veri merkezlerine ve altyapıya fiziksel zarar verebilir.

Elektrik Kesintileri (Power Outages)

•Açıklama:

Ani enerji kaybı, sistemlerin durmasına veya verilerin kaybolmasına neden olabilir.

Yangın (Fire)

•Açıklama:

Veri merkezlerinde yangın çıkması, fiziksel altyapıya büyük zarar verebilir.



Yeni Tehditler (Güncel)

IoT (Nesnelerin İnterneti) Güvenlik Açıkları:

IoT cihazları (akıllı ev cihazları, sensörler, akıllı saatler) genellikle düşük güçlü işlemcilerle çalışır ve yeterli güvenlik önlemleri alınmamış olabilir.

Örnek Olay

2016 yılında tüm dünyayı etkisine alan bir saldırı gerçekleşti. Bu saldırı IOT cihazları hedef alarak kendine bağlı olan tüm cihazları aynı anda etkileme oranına sahipti. Ve böylece birden fazla cihaza bağlanma özelliğine sahipti. Aslında bu saldırıyı gerçekleştiren yazılım Mirai adında Japonca da “gelecek” anlamıyla bilinen bir Botnet’ dir.

Eylül ayında gerçekleşen **Mirai Botnet** saldırısı birçok yerin güvenlik kameralarının bağlı olduğu sunuculara DDOS saldırı yöntemiyle gerçekleşti. Saldırı sonucu yaklaşık 25 bin kameranın görüntüleri elde edildiği gibi başta Asya ülkeleri olmak üzere Çin, Güney Kore gibi birçok ülkede de görüntüler ele geçirildi.

Alarm sistemi, modem, kombi, güvenlik kamerası gibi birçok Mirai botnetinde hedef olarak yer aldı.

Yeni Tehditler (Güncel)

AI Destekli Saldırıları:

Yapay zeka, saldırganların daha sofistike ve kişiselleştirilmiş saldırılar gerçekleştirmesine olanak tanır. Büyük veri setleri kullanarak hedef kişilerin davranışlarını analiz edebilir ve sosyal mühendislik saldırılarını daha etkili hale getirebilir.

Örnek Olaylar

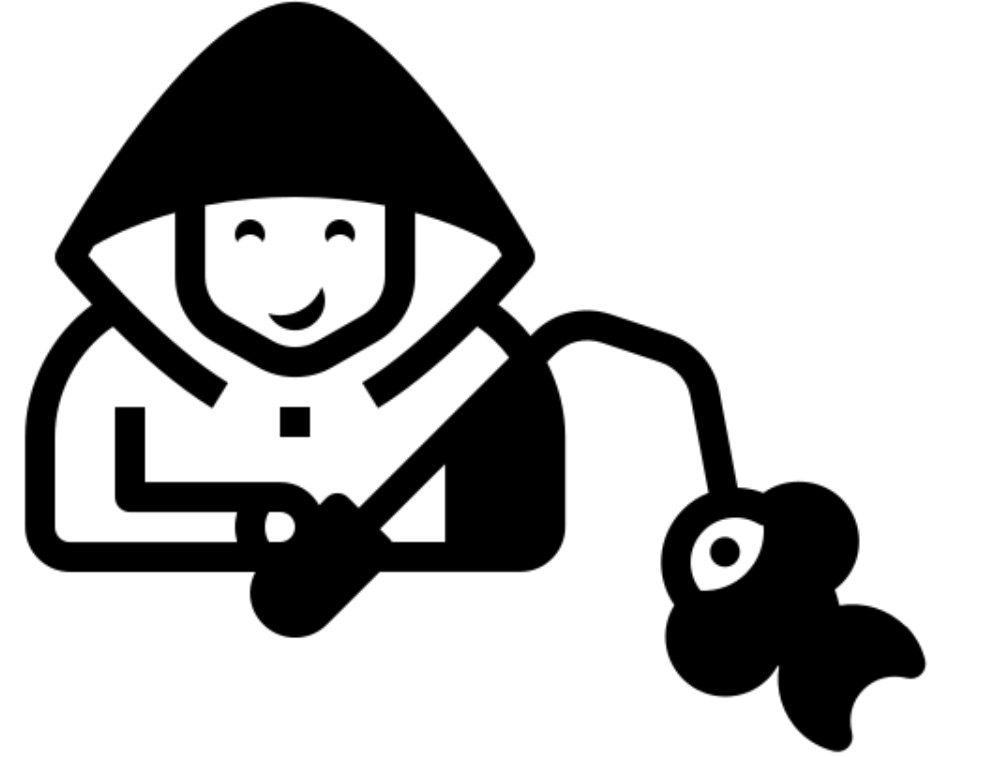
- Gelişmiş Phishing E-postaları:** AI, hedef kişinin sosyal medya gönderilerini analiz ederek daha ikna edici ortalama e-postaları oluşturabilir. Örneğin, kişinin son tatilini referans alan bir e-posta ile parola bilgileri talep edilebilir.
- Deepfake Videolar:** Bir CEO'nun sahte videosu yapılarak çalışanlardan büyük miktarda para transferi yapmaları istenebilir.
- 2019'da bir şirket, deepfake bir ses kaydına dayanarak 243 bin dolar kaybetti. →→→

Yeni Tehditler (Güncel)

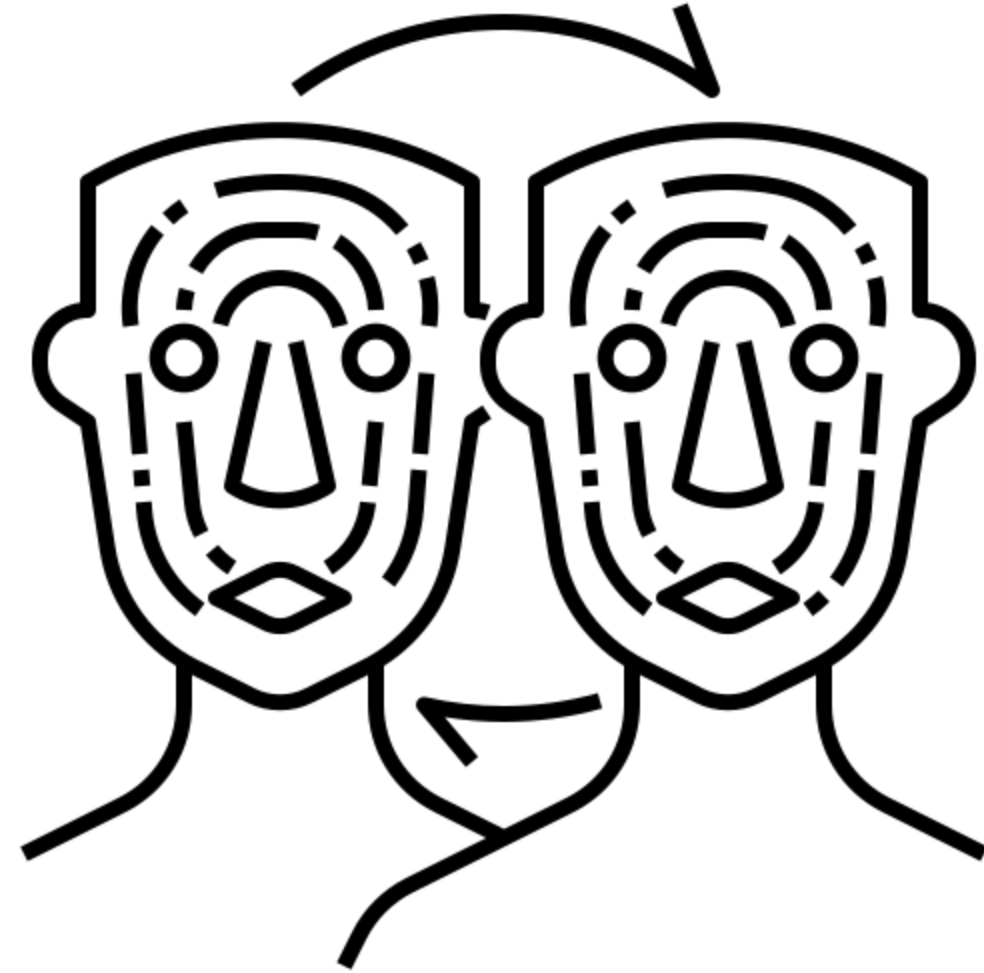
2019 yılında, yapay zeka destekli ses klonlama teknolojisi kullanılarak gerçekleştirilen bir dolandırıcılık vakasında, Birleşik Krallık'ta faaliyet gösteren bir enerji şirketinin CEO'su, patronu zannettiği kişinin talimatıyla 243 bin dolar değerinde bir para transferi gerçekleştirdi.

Dolandırıcılar, yapay zeka kullanarak şirketin Alman ana şirketinin CEO'sunun sesini taklit ettiler. Bu sahte sesle İngiltere'deki CEO'yu arayarak, acil bir ödeme yapılması gerektiğini söylediler.

Patronunun sesini tanıyan ve aksanını duyan CEO, hiçbir şeyden şüphelenmeden belirtilen hesaba 243 bin doları aktardı.



DeepFake Örnek



Yeni Tehditler (Güncel)

Kuantum Bilgisayarlar:

Kuantum bilgisayarlar, geleneksel bilgisayarlara göre çok daha hızlı işlem yapabilme kapasitesine sahiptir. Özellikle şifreleme algoritmalarını kırmada büyük bir tehdit oluşturabilir. RSA ve AES gibi algoritmalar, kuantum bilgisayarlar tarafından hızla etkisiz hale getirilebilir.

Örnek Olaylar

- RSA Şifreleme Tehdidi:** RSA algoritması, asal çarpanlara ayırma temeline dayanır. Kuantum bilgisayarlar, Shor algoritması sayesinde bu işlemi çok daha hızlı yapabilir.
- Blockchain Sistemlerine Tehdit:** Bitcoin gibi blok zinciri teknolojilerinde kullanılan şifreleme yöntemleri kuantum bilgisayarlar tarafından kırılabilir.

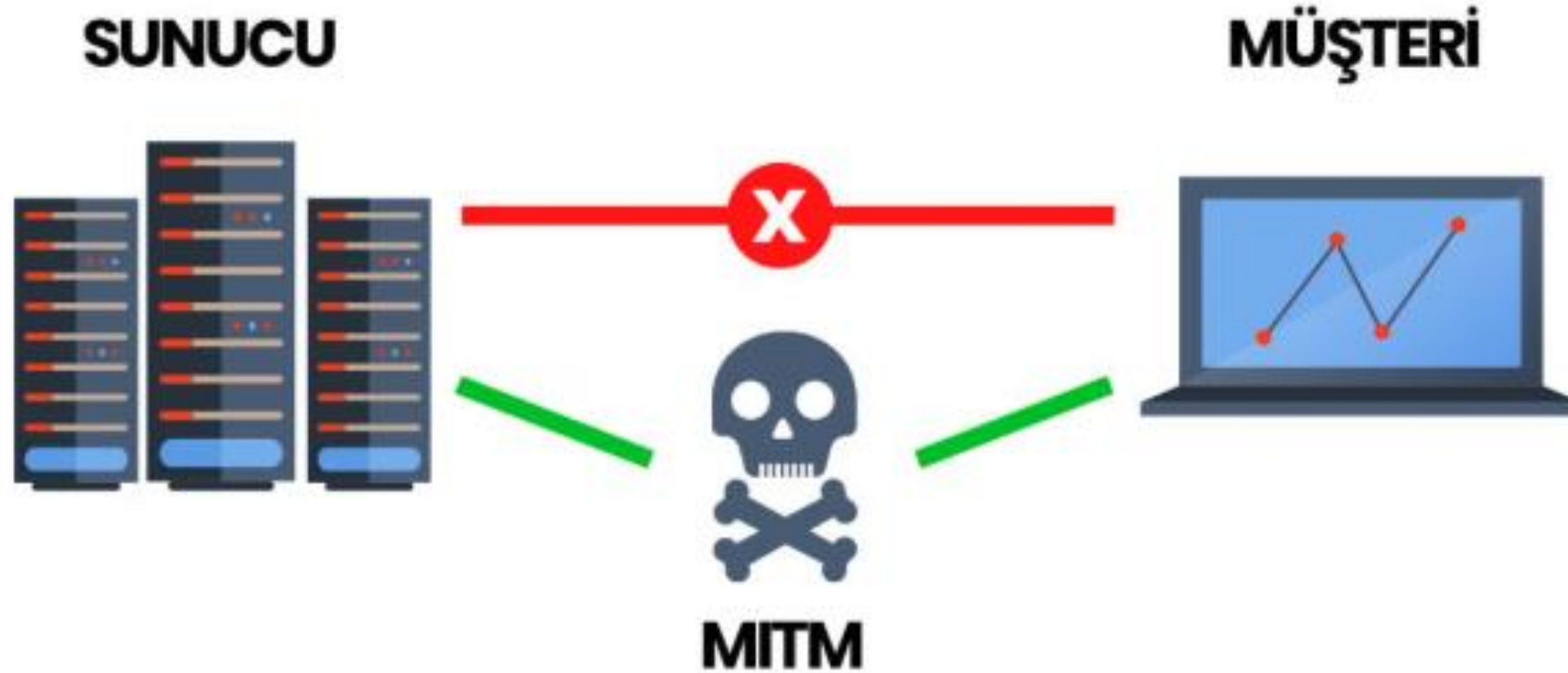
Post-Quantum Cryptography ???

Teknik Saldırılar

- SQL Injection, Cross-Site Scripting (XSS).
- Brute Force (Şifre Deneme) Saldırıları.
- Man-in-the-Middle (Ortadaki Adam) saldırıları. (MITM)



MITM



Gizli bir dinleme sayılan, gerçek zamanlı konuşmaları ve veri aktarımını açığa çıkaran ortadaki adam saldırıları bir tür oturum kaçırmadır.